



SILHOUETTE LLC

Kalihi Palama Health Center - Incident Response Plan Gap Analysis

Kalihi Palama Health Center

May 21, 2026

Prepared by Silhouette LLC

Table of Contents

1	Introduction	Scope, document reviewed, and standards evaluated
2	Executive Summary	Overall compliance posture and score breakdown
3	Gap Analysis	Detailed findings across all evaluated controls (93 total)
4	Priority Remediation Roadmap	Phased action plan with timelines and control references
5	Conclusion and Limitations	Key takeaways, scope boundaries, and recommended next steps

Scope & Methodology

PURPOSE

Silhouette LLC is conducting this Combined Gap Analysis on behalf of Kalihi Palama Health Center to assess readiness across applicable regulatory frameworks. The objective of this engagement is to provide a clear, evidence-based view of where documentation and controls stand today, and to deliver a prioritized roadmap that guides the organization toward full compliance.

DOCUMENTS REVIEWED (10)

- 1 **Data breach response plan.pdf**
- 2 **Incident response contact tree.pdf**
- 3 **Incident Response Plan.pdf**
- 4 **Malware infected system.pdf**
- 5 **Power outage procedures.pdf**
- 6 **Ransomware.pdf**
- 7 **Sentinel One (endpoint protection) meltdown protocol; Bad update.pdf**
- 8 **Spam_Phishing emails.pdf**
- 9 **User account Email compromised.pdf**
- 10 **User clicks on suspicious link.pdf**

Organization: Kalihi Palama Health Center | Combined
Entity Classification: Covered Entity (CE)

STANDARDS EVALUATED

- **NIST Standards**
 - **NIST SP 800-53 Rev 5** - Security and privacy controls framework for federal information systems, applied broadly to healthcare IT environments.
 - **NIST Cybersecurity Framework 2.0 (CSF)** - Voluntary framework providing a policy framework of computer security guidance for organizations to assess and improve their ability to prevent, detect, and respond to cyber attacks.
 - **NIST SP 800-66 Rev 2** - NIST implementation guidance for applying the HIPAA Security Rule, providing detailed mappings between HIPAA requirements and NIST SP 800-53 controls.
- **HIPAA Security & Privacy Rules** - Federal rules governing the protection and handling of protected health information (PHI) by covered entities and their business associates.
- **HITECH Act** - HITECH Act provisions strengthening HIPAA enforcement, expanding breach notification requirements, and establishing civil money penalty tiers.

METHODOLOGY

The analysis was performed by reviewing the submitted document against current authoritative control text retrieved directly from official regulatory sources (ecfr.gov, csrc.nist.gov, hhs.gov, and cms.gov). Each control was evaluated for one of three statuses:

Scope Limitations

This assessment covers the documentation submitted for review. The following limitations apply:

This assessment covers the documentation submitted for review. Operational controls and configurations not captured in the reviewed artifact are outside the scope of this analysis.

All findings are based on authoritative control text retrieved directly from official sources at the time of analysis. Regulatory requirements evolve and organizations should monitor for updates.

This report is informational and should be reviewed alongside qualified legal or compliance counsel before submission to any regulatory body.

Silhouette LLC uses AI to structure, format, and consistently present findings across engagements. All analysis and scoring has been reviewed for accuracy by our compliance team.

How Scoring Works

Step 1 - Identify applicable controls per standard

For each selected standard (e.g. NIST SP 800-53), we identify the controls relevant to the document type being reviewed, such as IR-1 through IR-10 for an Incident Response Plan.

Step 2 - Each control is evaluated against the submitted document

Yes - Fully addressed

Partial - Incomplete

No - Not addressed

Step 3 - Score is calculated per standard

Example: 19 NIST SP 800-53 controls reviewed against an Incident Response Plan

Yes: 4 (4.0 pts)

+

Partial: 9 (4.5 pts)

+

No: 6 (0 pts)

Credits earned: $4.0 + 4.5 + 0 = 8.5$ | Score: $8.5 \div 19 \times 100 = 44.7$

Partially Compliant

≥85 Compliant

50-84 Partially Compliant

<50 Non-Compliant

Compliance Posture Overview

11

LOW

30

MEDIUM

35

HIGH

17

CRITICAL

93

TOTAL



OVERALL COMPLIANCE SCORE

Non-Compliant

Kalihi Palama Health Center exhibits critical compliance gaps across HIPAA, HITECH, and NIST controls (SP 800-53, CSF 2.0, SP 800-66r2), with no breach notification procedures, no risk analysis, no business associate agreements, and no contingency or disaster recovery plans documented. The organization's incident response documents address operational steps for individual scenarios but lack the foundational compliance framework required of a covered entity, creating substantial regulatory exposure including potential civil money penalties. Immediate remediation is required across notification obligations, risk management, workforce training, and contingency planning to achieve a baseline compliant posture.

NIST (SP 800-53, CSF 2.0, SP 800-66r2)		43 / 100	13 met 12 partial 19 failed
HIPAA Security & Privacy Rules		15 / 100	3 met 4 partial 26 failed
HITECH Act		9 / 100	0 met 3 partial 13 failed

SCORING METHODOLOGY

- **Compliant (85-100)** - All or nearly all required controls addressed with adequate documentation
- **Partially Compliant (50-84)** - Core controls present but gaps exist in required or addressable safeguards
- **Non-Compliant (<50)** - Significant required controls absent; material regulatory exposure

Each control is scored **Yes** (1.0), **Partial** (0.5), or **No** (0). The score is the percentage of credits earned out of total controls reviewed. Critical and High gaps carry additional qualitative weight. Scores reflect the submitted document only and do not account for compensating controls.

Detailed Findings

A total of 93 findings: 17 Critical, 35 High, 30 Medium, 11 Low.

Control	Requirement	Status	Risk	Gap Description
13400 HITECH	Covered entities must notify individuals, HHS, and media of breaches as defined under HITECH.	No	Critical	HITECH breach notification obligations are entirely absent; only FBI and insurance are notified.
13401 HITECH	Business associates must comply with HIPAA Security Rule safeguards under HITECH Section 13401.	No	High	Entity type is unknown; no BAA references, security safeguard documentation, or HITECH compliance program is present.
13402 HITECH	Notify affected individuals, HHS, and media (if applicable) following discovery of a breach of unsecured ePHI.	No	Critical	No breach notification policy, procedure, timeline, or responsible party is identified anywhere in the document.
13407 HITECH	Business associates must notify covered entities of breaches without unreasonable delay and within 60 days.	Partial	High	Vendor notification is acknowledged as a trigger but no formal BA notification agreement, timeline, or protocol is defined.
13411 HITECH	HHS must conduct periodic audits of covered entities and business associates for HIPAA compliance.	Partial	Medium	Annual review and testing referenced but no OCR audit readiness, documentation retention, or audit response procedures defined.
13412 HITECH	State attorneys general may bring civil actions for HIPAA violations affecting state residents.	Partial	Medium	Legal counsel role and regulatory compliance commitment present but no state AG enforcement awareness or state-specific obligations defined.
IR-1 NIST	Develop, document, disseminate, review, and update incident response policy and procedures	Yes	Medium	A rudimentary procedure exists for this specific scenario, partially satisfying the procedural element, though not a formal reviewed policy.
IR-4 NIST	Implement IR capability including preparation, detection, analysis, containment, eradication, and recovery.	Yes	Medium	All six core IR handling phases are addressed with named personnel, tools (SentinelOne), and procedures.
IR-5 NIST	Track and document incidents on an ongoing basis.	Yes	Low	Ongoing incident logging documented with required data fields; Google Docs designated as the logging platform.
IR-6 NIST	Report security incidents to organizational officials and external authorities within defined timeframes	Yes	High	External law enforcement and government reporting contacts are present. No timeframes for reporting are defined.

Control	Requirement	Status	Risk	Gap Description
IR-7 NIST	Provide IR support resources, including access to outside counsel and forensic assistance.	Yes	Medium	Plan references engagement of recovery company and legal counsel through cybersecurity insurance provider, satisfying this control.
IR-8 NIST	Develop and distribute a formal IR plan that includes roles, metrics, reporting, and plan protection.	Partial	High	Formal IRP exists with roles and phases but lacks metrics for measuring effectiveness, resource requirements, and plan classification.
IR-9 NIST	Respond to information spills by identifying contaminated systems and eradicating the spill.	Partial	High	Email purge and endpoint scanning are addressed, but no formal data spill response procedure or PHI-specific containment steps are defined.
IR-2 NIST	Provide IR training to system users consistent with assigned roles and responsibilities.	No	Medium	No training requirements, frequency, or role-based IR training program is mentioned anywhere in the document.
IR-3 NIST	Test the IR capability using defined tests and exercises at defined frequency.	Partial	Medium	Tabletop exercises mentioned but no defined frequency, scope, success criteria, or records requirement provided.
AU-6 NIST	Review and analyze audit records for indications of inappropriate activity and report findings.	Partial	High	Log review is referenced as a validation mechanism but no formal audit review process, frequency, or reporting chain is defined.
CP-2 NIST	Develop a contingency plan that addresses essential missions and business functions.	Partial	High	Contingency scenarios acknowledged via references to linked plans but no BCP/DRP content or RTO/RPO objectives present.
RA-3 NIST	Conduct risk assessment identifying threats, vulnerabilities, likelihood, and impact to operations and assets.	No	Critical	No risk assessment process, threat modeling, or breach risk scoring methodology is described anywhere in the plan.
164.308(a)(6)(i) HIPAA	Implement policies and procedures to address security incidents.	Yes	Medium	Security incident response policies and procedures are documented with defined phases, roles, and tools.
164.308(a)(6)(ii) HIPAA	Identify and respond to suspected or known security incidents; mitigate harmful effects; document outcomes.	Yes	High	Document provides response steps and logging direction; FBI and insurance notification are included.
164.400 HIPAA	Covered entities must notify affected individuals, HHS, and media (if applicable) following discovery of a breach of unsecured PHI.	No	Critical	No notification requirements to individuals, HHS Secretary, or media are mentioned. HIPAA breach notification rule is entirely absent.

Control	Requirement	Status	Risk	Gap Description
164.404 HIPAA	Notify affected individuals without unreasonable delay and within 60 calendar days of breach discovery.	No	Critical	The mandatory 60-day individual notification requirement, content requirements, and delivery methods are entirely absent.
164.408 HIPAA	Notify HHS Secretary of breaches; immediately for 500+ individuals, annually for smaller breaches.	No	Critical	No HHS Secretary notification requirement, timeline, or reporting portal reference is included in the plan.
164.414 HIPAA	Covered entities must document all notifications and retain documentation for 6 years.	No	High	No documentation retention requirements, 6-year retention standard, or burden-of-proof procedures are described.
164.312(b) HIPAA	Implement hardware, software, and/or procedural mechanisms that record and examine activity in systems containing ePHI.	Partial	High	System logs are referenced for validation but no formal audit control implementation or review procedure is described.
13402(a) HITECH	Covered entities must notify individuals of breaches of unsecured PHI in accordance with HIPAA breach notification rule.	No	Critical	HITECH-mandated individual breach notification obligations are entirely absent from the plan.
13410(d) HITECH	Violations subject to tiered CMPs: up to \$2,067,813 per violation category per year (2024 inflation-adjusted figures).	No	High	No reference to HITECH penalty tiers, compliance obligations, or risk of CMPs is included to inform response urgency.
13402(f) HITECH	Breach notifications must include description of breach, types of PHI, steps individuals should take, and contact information.	No	Critical	No notification content requirements, template, or prescribed elements for breach notices to individuals are included.
SI-5 NIST	Receive security alerts from external organizations and disseminate to relevant personnel	No	Medium	No process for receiving or acting on US-CERT, HHS, or vendor security advisories is described.
AC-2 NIST	Manage system accounts including establishing, activating, modifying, and disabling.	Partial	Medium	Credential change during containment mentioned but no formal account management, provisioning, or disabling procedures defined.
PM-12 NIST	Implement an insider threat program including detection, prevention, and response capabilities	No	Medium	HR involvement mentioned for employee-related incidents but no insider threat program or procedures defined.
SA-9 NIST	Require external service providers to comply with security requirements and employ appropriate controls	No	Medium	IT consultant Achyut P. listed but no BAA, security requirements, or oversight of third-party vendors mentioned.

Control	Requirement	Status	Risk	Gap Description
164.308(a)(1)(ii)(A) HIPAA	Conduct accurate and thorough assessment of potential risks to ePHI confidentiality, integrity, and availability	No	Critical	No risk analysis referenced. Required under HIPAA Security Rule as foundational control.
164.308(a)(2) HIPAA	Identify the security official responsible for developing and implementing security policies and procedures	Yes	Medium	A named compliance official is identified with contact information and assigned incident liaison responsibilities.
164.308(a)(5)(ii)(C) HIPAA	Implement procedures for monitoring log-in attempts and reporting discrepancies (Addressable).	Partial	High	MimeCast review mentioned for suspicious activity but no formal login monitoring policy, frequency, or discrepancy reporting process defined.
164.310(d)(2)(iv) HIPAA	Create and maintain retrievable exact copies of ePHI	No	High	No backup, restoration, or data recovery procedures mentioned in the document.
164.312(a)(2)(ii) HIPAA	Establish and implement procedures for obtaining necessary ePHI during an emergency	No	High	No emergency access to ePHI procedures defined. Contact tree does not address clinical continuity.
164.314(a)(1) HIPAA	Covered entity must have written contracts with business associates that comply with HIPAA requirements	No	High	IT consultant listed with no mention of BAA. No vendor contract or BAA requirements referenced.
164.406 HIPAA	Notify prominent media outlets for breaches affecting more than 500 residents of a state or jurisdiction	No	High	Document prohibits media contact without defining required media notification for large breaches under 164.406.
164.530(b) HIPAA	Train workforce members on policies and procedures as necessary for carrying out their functions	No	High	No workforce training requirements, schedules, or documentation referenced in the document.
13402(e)(4) HITECH	Report breaches affecting fewer than 500 individuals to HHS annually	No	High	Annual HHS log reporting for small breaches not referenced. No breach log or tracking mechanism defined.
13402(b) HITECH	Business associates must notify covered entities of breaches without unreasonable delay and within 60 days of discovery	No	High	No BA breach notification requirements or contractual obligations referenced despite listing external IT consultant.
AU-11 NIST	Retain audit records for defined period to support post-incident investigations.	No	Medium	No retention period specified for Google Docs logs or any other incident records.
CP-9 NIST	Conduct backups of user-level, system-level, and security-related documentation.	Partial	Medium	Secure backups referenced for recovery but no backup frequency, retention, testing, or offsite storage details provided.

Control	Requirement	Status	Risk	Gap Description
RA-5 NIST	Monitor and scan for vulnerabilities in organizational systems.	No	Medium	No vulnerability scanning process, tools, or schedule referenced; Section 4.1 defers entirely to a separate security plan.
SI-3 NIST	Implement malicious code protection mechanisms at system entry and exit points.	Yes	Low	SentinelOne endpoint protection and malware removal procedures are explicitly referenced and linked to named scenarios.
SI-4 NIST	Monitor systems to detect attacks, indicators of potential attacks, and unauthorized connections.	Yes	Low	Monitoring for suspicious activity is defined with a named responsible individual and alert-handling process.
PM-16 NIST	Implement a threat awareness program that includes a cross-organization information-sharing capability.	Yes	Low	Document references external threat intelligence (HavelBeenPwned, Proofpoint) for awareness; meets minimum intent of this control.
IR-10 NIST	Establish an integrated team of forensic/malware analysts to support IR.	Partial	Low	IRT with Technical Lead and vendor escalation defined but no dedicated forensics analyst or integrated analysis team documented.
164.308(a)(1)(ii)(B) HIPAA	Implement security measures to reduce risks to ePHI to a reasonable and appropriate level.	No	Critical	No risk management program, risk treatment decisions, or ePHI-specific security measures documented.
164.308(a)(5)(ii)(B) HIPAA	Procedures for guarding against, detecting, and reporting malicious software.	Partial	High	Malware detection and removal covered but staff reporting procedures and user-level malicious software guidance are absent.
164.310(a)(2)(i) HIPAA	Establish procedures to allow facility access to support data restoration under a disaster recovery plan.	No	High	No facility access contingency procedures or disaster recovery access controls defined.
164.314(a)(2)(i) HIPAA	Ensure business associate agreements are in place for entities handling ePHI.	No	High	Section 2 covers vendors and third parties in scope but no BAA requirements or BA notification procedures defined.
SP800-66r2-4.1 NIST	Document IR plan with scope, roles, communication, and integration with contingency plan.	Partial	Medium	Core IR plan elements present but CP integration, resource requirements, and plan protection are absent.
SP800-66r2-4.2 NIST	IR procedures must address identification and protection of ePHI during incident response.	No	Critical	No ePHI identification, classification, or specific protection steps during IR phases referenced anywhere in the document.
SP800-66r2-4.3 NIST	Apply appropriate sanctions to workforce members who fail to comply with IR policies.	No	Low	No sanction policy or disciplinary process for IR non-compliance referenced in the document.

Control	Requirement	Status	Risk	Gap Description
SP800-66r2-5.1 NIST	Implement specific procedures for ransomware and malware incident response aligned with HIPAA requirements.	Yes	Low	Ransomware and malware specific response plans referenced with tool-level detail; dedicated playbooks linked.
SP800-66r2-5.2 NIST	Conduct post-incident analysis to improve IR capabilities and update the IR plan.	Yes	Low	Robust post-incident review process with lessons learned, reporting, action plans, and plan updates explicitly defined.
SI-7 NIST	Employ integrity verification tools to detect unauthorized changes to software and information.	No	Medium	No integrity checking, file hashing, or change detection beyond SentinelOne EDR signatures is documented.
164.312(a)(1) HIPAA	Implement technical policies and procedures to allow only authorized persons access to ePHI.	No	High	No access control policy for ePHI systems, role-based access, or minimum necessary standard is documented.
13402(e) HITECH	Notify the HHS Secretary of breaches affecting 500 or more individuals immediately; others in annual log.	No	Critical	FBI notification mentioned for ransomware but no HHS Secretary notification procedure, thresholds, or annual log process exist.
CP-4 NIST	Test the contingency plan to determine effectiveness and readiness.	No	High	No testing schedule, test results, or after-action review process is referenced anywhere in the document.
CP-8 NIST	Establish alternate telecom services to maintain operations during disruption.	Partial	High	Phone service impact is acknowledged but no alternate telecom continuity plan or failover service is defined.
CP-10 NIST	Provide for recovery and reconstitution of the system to a known state after disruption	Partial	Medium	Recovery steps for the specific scenario exist but no formal reconstitution process, verification, or return-to-operations criteria.
SI-2 NIST	Identify, report, and correct information system flaws; install security updates.	No	Medium	No patch management or flaw remediation process is referenced. Out of scope for a power alert document but required for overall compliance.
PE-11 NIST	Provide short-term uninterruptible power and long-term alternate power for the system.	Yes	Low	Generator circuit monitoring is in place at the primary server room, demonstrating awareness of emergency power infrastructure.
164.308(a)(7)(i) HIPAA	Establish and implement policies to respond to emergencies that damage systems containing ePHI.	No	Critical	No HIPAA contingency plan exists. Document addresses operational alerts only with no ePHI protection or recovery procedures.
164.308(a)(7)(ii)(A) HIPAA	Establish and implement procedures to create and maintain retrievable exact copies of ePHI.	No	Critical	No data backup plan or ePHI backup procedures are referenced in this document.

Control	Requirement	Status	Risk	Gap Description
164.308(a)(7)(ii)(B) HIPAA	Establish procedures to restore loss of data in the event of a fire, vandalism, disaster, or system failure.	No	Critical	Disaster recovery procedures for ePHI restoration are entirely absent from this document.
164.308(a)(7)(ii)(C) HIPAA	Establish procedures to enable continuation of critical business processes protecting ePHI during an emergency.	No	Critical	No emergency mode operation plan is documented. No procedures exist for maintaining ePHI access or protection during a power outage.
164.308(a)(7)(ii)(D) HIPAA	Implement procedures for periodic testing and revision of contingency plans.	No	High	No testing or revision schedule exists for any contingency or alert procedure referenced in this document.
164.310(a)(2)(ii) HIPAA	Implement policies to safeguard the facility and equipment from unauthorized physical access.	Partial	Medium	Physical surveillance cameras are deployed at multiple sites but no formal facility security plan, access control policy, or visitor management procedure is documented.
SC-7 NIST	Monitor and control communications at external and internal boundaries	Yes	Low	Document explicitly directs network isolation for affected systems, implementing boundary protection during incident response.
164.312(a)(2)(i) HIPAA	Assign unique names or numbers for identifying and tracking user identity.	No	Medium	No user identification or credential management procedures are defined in the document.
13402(j) HITECH	PHI rendered unusable through encryption or destruction is exempt from breach notification.	No	High	No encryption policy, safe harbor strategy, or data classification criteria are mentioned.
164.530(j) HIPAA	Retain required documentation for 6 years from date of creation or last effective date.	No	Medium	Google Docs logging is mentioned but no retention period, ownership, or archive policy is defined.
164.308(a)(7)(ii)(E) HIPAA	Implement procedures for periodic testing and revision of contingency plans.	No	Medium	No testing schedule, revision cycle, or plan update process is referenced in the document.
CM-3 NIST	Document, approve, and control changes to the information system configuration	No	High	No change management or change control process defined. Updates are blocked reactively with no formal approval workflow.
CM-6 NIST	Establish and document configuration settings for IT products and enforce them	No	Medium	No baseline configuration standards referenced. Systems identified as running old Windows versions with no remediation timeline.
13410(a) HITECH	HHS may audit covered entities and BAs for HIPAA compliance; organizations must maintain required documentation	No	High	No audit readiness, documentation retention, or policy review process is present. Document would not meet OCR audit protocol requirements.

Control	Requirement	Status	Risk	Gap Description
SI-8 NIST	Employ spam protection mechanisms at information system entry and exit points.	Yes	Low	Mimecast and Proofpoint are deployed for spam filtering. Blocklisting and email recall procedures are documented.
AU-2 NIST	Identify events to be logged and coordinate the event logging function.	No	Medium	No event logging policy or list of auditable events is defined. SysAid ticket logging is mentioned but is not an audit logging control.
AC-17 NIST	Establish and document usage restrictions and implementation guidance for remote access.	No	Medium	Remote access controls are not addressed in this document. No remote access policy or restrictions are defined.
AT-2 NIST	Provide security awareness training to all users as part of initial and ongoing training.	No	Medium	No security awareness training program is described. KnowBe4 is used as a reporting button, but no training curriculum or schedule is mentioned.
164.312(a)(2)(iv) HIPAA	Implement mechanism to encrypt and decrypt ePHI where appropriate.	No	High	No encryption controls are referenced for email containing ePHI. The document does not address email encryption at rest or in transit.
164.402 HIPAA	Define what constitutes a breach of unsecured PHI requiring notification under the Breach Notification Rule.	No	Critical	No breach definition or notification trigger is present. Document does not address whether email incidents involving PHI constitute a reportable breach.
AC-7 NIST	Enforce limit of consecutive invalid logon attempts; lock account for defined period after limit exceeded.	No	High	No lockout policy, thresholds, or automatic account locking mechanism is described in the document.
IA-5 NIST	Manage system authenticators including password complexity, change frequency, and revocation.	Partial	High	Password change reminders and uniqueness mentioned but no complexity, minimum length, history, or MFA requirements are defined.
PL-2 NIST	Develop, document, and periodically update a security and privacy plan that describes controls in place.	No	Medium	No system security plan, scope statement, ownership, or review schedule exists in this document.
164.312(d) HIPAA	Implement procedures to verify that a person or entity seeking access to ePHI is the one claimed.	No	High	No authentication controls, MFA, or identity verification procedures for ePHI system access are mentioned.
13401(a) HITECH	Business associates must comply with HIPAA Security Rule requirements directly under HITECH.	No	High	No BA agreements, BA security obligations, or downstream compliance requirements are addressed.

Control	Requirement	Status	Risk	Gap Description
13405(c) HITECH	Covered entities and business associates must not sell PHI without valid authorization except in permitted circumstances.	No	High	No PHI use restrictions, sale prohibitions, or data handling obligations are described in the document.
164.410 HIPAA	Notify prominent media outlets for breaches affecting more than 500 residents of a state or jurisdiction.	No	Medium	No media notification requirement or threshold assessment is mentioned in the document.

Priority Remediation Roadmap

Actions organized by risk level and urgency. Cross-referenced to Section 3 findings.

Phase 1 - Critical Regulatory Foundations

0-30 days

1

Develop HIPAA-HITECH Breach Notification Policy

Draft and adopt a breach notification policy covering 60-day individual notice, HHS Secretary reporting via OCR portal, and media notification for breaches over 500 individuals.

164.400 (HIPAA)

164.404 (HIPAA)

164.406 (HIPAA)

164.408 (HIPAA)

13400 (HITECH)

13402 (HITECH)

13402(a) (HITECH)

13402(f) (HITECH)

2

Conduct Formal HIPAA Security Risk Analysis

Engage qualified personnel or a third party to perform a documented risk analysis identifying threats, vulnerabilities, likelihood, and impact to all ePHI systems.

164.308(a)(1)(ii)(A) (HIPAA)

RA-3 (NIST)

SP800-66r2-4.2 (NIST)

3

Establish Risk Management Program

Implement a written risk management plan documenting security measures selected to reduce ePHI risks to reasonable and appropriate levels, tied to risk analysis findings.

164.308(a)(1)(ii)(B) (HIPAA)

SP800-66r2-4.1 (NIST)

4

Execute Business Associate Agreements

Identify all vendors and contractors handling ePHI including the IT consultant, execute HIPAA-compliant BAAs, and document BA breach notification obligations within 60 days.

164.314(a)(1) (HIPAA)

164.314(a)(2)(i) (HIPAA)

13401 (HITECH)

13402(b) (HITECH)

13407 (HITECH)

SA-9 (NIST)

5

Create Breach Log and Annual HHS Reporting Process

Establish a breach tracking log for incidents affecting fewer than 500 individuals and define the annual HHS reporting workflow including responsible owner and submission timeline.

164.414 (HIPAA)

13402(e)(4) (HITECH)

13402(e) (HITECH)

164.408 (HIPAA)

Phase 2 - Contingency Planning and Access Controls

31-60 days

6**Develop HIPAA Contingency Plan Suite**

Create documented data backup plan, disaster recovery plan, emergency mode operation plan, and contingency testing procedures covering all ePHI systems per 164.308(a)(7).

164.308(a)(7)(i) (HIPAA)

164.308(a)(7)(ii)(A) (HIPAA)

164.308(a)(7)(ii)(B) (HIPAA)

164.308(a)(7)(ii)(C) (HIPAA)

164.308(a)(7)(ii)(D) (HIPAA)

CP-2 (NIST)

7**Define Backup, Recovery, and Reconstitution Procedures**

Document backup frequency, offsite storage, retention periods, test restoration schedule, and formal return-to-operations criteria for all ePHI systems.

CP-9 (NIST)

CP-10 (NIST)

164.310(d)(2)(iv) (HIPAA)

164.310(a)(2)(i) (HIPAA)

8**Implement ePHI Access Control Policy**

Define role-based access controls, minimum necessary standard, unique user identification, emergency access procedures, and credential lifecycle management for all ePHI systems.

164.312(a)(1) (HIPAA)

164.312(a)(2)(i) (HIPAA)

164.312(a)(2)(ii) (HIPAA)

AC-2 (NIST)

9**Establish Formal Audit Control and Log Review Procedures**

Define audit logging requirements for all ePHI systems, establish review frequency and escalation chain, and set minimum 6-year documentation retention policy.

164.312(b) (HIPAA)

164.414 (HIPAA)

AU-6 (NIST)

AU-11 (NIST)

10**Update Incident Response Plan with Compliance Requirements**

Revise IRP to add ePHI identification steps, response metrics, plan protection classification, resource requirements, and integration with the contingency plan.

IR-8 (NIST)

SP800-66r2-4.1 (NIST)

SP800-66r2-4.2 (NIST)

CP-2 (NIST)

Phase 3 - Workforce, Training, and Detection Capabilities

61-90 days

11 Launch Role-Based HIPAA and IR Training Program

Develop and deliver HIPAA workforce training and role-specific IR training, document completion, and define recurring frequency and refresher requirements for all staff.

164.530(b) (HIPAA)

IR-2 (NIST)

SP800-66r2-4.3 (NIST)

12 Define Malicious Software and Phishing Reporting Procedures

Create user-facing procedures for reporting suspicious email, malware, and phishing attempts, integrating with MimeCast and SentinelOne workflows and escalation path.

164.308(a)(5)(ii)(B) (HIPAA)

164.308(a)(5)(ii)(C) (HIPAA)

IR-9 (NIST)

13 Establish Vulnerability Management and Patch Program

Define vulnerability scanning schedule, tooling, remediation SLAs, and patch management process covering all ePHI-adjacent systems and endpoints.

RA-5 (NIST)

SI-2 (NIST)

SI-7 (NIST)

14 Implement Security Alerts and Advisory Intake Process

Subscribe to HHS, US-CERT, and vendor security advisories and create a documented process for triaging, disseminating, and acting on external threat intelligence.

SI-5 (NIST)

IR-8 (NIST)

15 Conduct Incident Response and Contingency Tabletop Exercises

Schedule and execute tabletop exercises for breach, ransomware, and power outage scenarios with defined frequency, success criteria, and after-action documentation requirements.

IR-3 (NIST)

CP-4 (NIST)

164.308(a)(7)(ii)(D) (HIPAA)

Phase 4 - Program Maturity and Ongoing Compliance

91-180 days

16

Develop OCR Audit Readiness and Documentation Retention Plan

Compile required HIPAA policy documentation, establish 6-year retention schedule, assign document owner, and create an OCR audit response playbook.

13411 (HITECH)

164.414 (HIPAA)

AU-11 (NIST)

17

Establish State AG Enforcement Awareness Program

Brief legal counsel on Hawaii state attorney general HIPAA enforcement authority, document state-specific obligations, and integrate into the legal response section of the IRP.

13412 (HITECH)

IR-8 (NIST)

18

Implement Insider Threat Program

Develop written insider threat policy covering detection indicators, HR integration, monitoring procedures, sanction policy, and incident escalation path for workforce-related threats.

PM-12 (NIST)

SP800-66r2-4.3 (NIST)

19

Formalize BA Notification Protocol and 13407 Compliance

Define contractual BA notification timelines, designate receiving contact, create intake procedures for vendor-reported breaches, and confirm 60-day notification SLA in all BAAs.

13407 (HITECH)

13402(b) (HITECH)

164.314(a)(1) (HIPAA)

20

Define Encryption Policy and PHI Safe Harbor Strategy

Adopt an encryption standard for ePHI at rest and in transit, document safe harbor eligibility criteria, and integrate data classification into breach risk assessment procedures.

13402(j) (HITECH)

CP-8 (NIST)

164.312(a)(1) (HIPAA)

Conclusion & Limitations

KEY TAKEAWAYS

- This assessment identified **17 Critical findings** requiring immediate attention. These represent material regulatory exposure and should be escalated to leadership.
- The lowest-scoring standard evaluated was **HITECH Act** at **9/ 100**, suggesting this area warrants focused remediation investment.
- 19 controls were rated Partial, indicating that foundational elements exist but require enhancement to achieve full compliance. These represent an efficient remediation opportunity.

RECOMMENDED NEXT STEPS

Based on the findings in this report, Silhouette LLC recommends the following immediate actions:

1. **Distribute to leadership.** Share this report with the appropriate compliance officer, IT leadership, and executive sponsor. Critical and High findings should be escalated immediately.
2. **Assign ownership.** Map each remediation roadmap item to a named owner with a documented due date aligned to the phase timeframes.
3. **Review the full policy inventory.** This analysis was limited to the submitted document. A comprehensive compliance program requires review of all applicable policies, procedures, and technical controls.
4. **Schedule a follow-up assessment.** Reassess compliance posture after the Immediate and Short-term phases are complete to verify remediation effectiveness and update the risk register.

THANK YOU

Next Steps

Engage Silhouette LLC to develop a remediation plan addressing the identified gaps and prioritize controls based on regulatory exposure and organizational risk tolerance.

This report is confidential and prepared solely for Kalihi Palama Health Center.